

ANALISIS Y PLANIFICACIÓN DEL PENTEST

Vanessa Valderrama

Hacker Women Council – Ethical Hacking

OBJETIVOS DEL PENTEST.

El objetivo principal es Identificar la existencia de vulnerabilidades en la gestión de sesiones y autorizaciones que permitan a un usuario ver, modificar o acceder a información personal de otras cuentas. Lo anterior, a raíz de una alerta que recibió el departamento de atención al cliente. El crecimiento de la empresa Aurora Market, ha hecho que su página web quede expuesta a nuevas vulnerabilidades. Con ello, se pretende probar la resistencia y seguridad del flujo de comercio electrónico y autenticación. La ejecución del pentest proporcionará un informe claro y conciso sobre los privilegios de usuarios y las fronteras de privacidad entre clientes. Este documento ayudara a identificar y mitigar la superficie de ataque para salvaguardar los principios básicos CIA; Confidencialidad, Integridad y Disponibilidad.

ALCANCE.

- Si se evaluará (sistemas o elementos incluidos en el alcance):
 - Aplicación web pública de comercio electrónico de Aurora Market
 - Panel web de administración/empleados.
 - Sistema interno de la página (Mecanismos de autenticación y control de sesiones).

- Fuera del alcance (elementos que no serán evaluados):
 - Redes sociales oficiales de la empresa.
 - Equipos personales de los empleados.
 - Correos electrónicos del personal.
 - Proveedores externos de la empresa.

AUTORIZACIÓN Y CONDICIONES.

- Permisos requeridos:

- Documentos legales donde Aurora Market autorice las pruebas pertinentes.
- Acuerdos de confidencialidad para cuidar y no revelar información privada.
- Condiciones acordadas:
 - No interrumpir deliberadamente el funcionamiento de la plataforma.
 - No afectar información real de los clientes.
 - Realizar las pruebas durante horarios de menor actividad.
 - Documentación detallada.

Con los puntos anteriores respecto a las condiciones acordadas se planifica que las pruebas se realicen durante la noche, aproximadamente de 01:30 am a 5:00 am en días de menor afluencia como lo son de lunes a jueves. Lo anterior, previene la posible interrupción de la navegación de los clientes en Aurora Market. Los horarios y días se escogieron basados en información general de menor actividad de aplicaciones web globales.

TIPO DE PENTEST.

GRAY-BOX

Aurora Market no entrego toda la información técnica ni el código interno de la página web. Sin embargo, si dio cierta información básica; el funcionamiento de la aplicación web, la existencia de una base de datos y los diferentes tipos de usuarios (clientes y administradores). Teniendo esta información parcial se puede simular ser un cliente promedio, navegar dentro de estos entornos para posteriormente, descubrir posibles áreas de mejora.

PLANIFICACIÓN.

- Objetivos:

Definir las metas concretas: entender la falla reportada de visualización cruzada y evaluar la resistencia de la tienda
- Alcance:

Establecer las URL exactas, formularios y endpoints que se evaluarán, descartando expresamente redes sociales y equipos de empleados.
- Permisos y condiciones:

Firmar el documento de autorización y convenir el horario nocturno/de baja actividad para las pruebas.
- Metodología a utilizar:

Elegir un marco de trabajo estándar de seguridad web (como OWASP) para asegurar que no se omita ninguna prueba esencial.
- Recopilación de información previa:

Para la recopilación de información utilizaremos tanto fuentes internas como fuentes abiertas (OSINT) esto debido a las situaciones específicas del caso. Abierta para recopilar información sobre; identificación de puertos; estructura web y rutas; páginas indexadas; infraestructura DNS y posibles subdominios asociados,

esto con herramientas como NMAP, OWASP ZAP y Google Dorks, los cuales nos ayudarán mapear y localizar. Por otra parte, también se utilizarán fuentes internas, debido a la situación es posible saber el contexto del reporte y algunos datos más acerca de la infraestructura, proporcionados por Aurora Market

- Recursos necesarios:

Preparar las herramientas como Nmap, OWASP ZAP, Burp Suite, Linux y de ser posible, Metasploit. De igual manera, los respectivos equipos físicos.

Elaborar un cronograma detallando los días y las horas exactas en que se realizarán las pruebas, mismas que se encuentran detalladas en el apartado de autorizaciones y condiciones.

FASE DEL PENTEST.

- Reconocimiento:

Mapear de forma pasiva y activa la superficie web de Aurora Market, principalmente:

Elemento por analizar	¿Para qué?	Herramienta utilizada
Archivos expuestos (OSINT)	Localizar rutas ocultas, directorios expuestos, documentos sensibles y código fuente.	Operadores de Google Dorks.
Puertos abiertos y servicios de la red	Saber que puertas de comunicación están activas en el servidor y detectar si se dejaron expuestos de accesos indebidos.	Nmap
Puntos de entrada	Ubicar todos los campos donde el usuario puede enviar información al servidor para saber dónde probar fallas posteriormente	OWASP ZAP

- Análisis de vulnerabilidades:

En esta fase se buscará examinar la lógica de la aplicación y la gestión de permisos. A través de OWASP ZAP y Burp Suite se detectará controles de accesos rotos, se revisará si el servidor comprueba la identidad de quien solicita la información y la inspección detallada de cada petición, errores en la gestión de sesiones.

- Explotación:

Intentar confirmar las sospechas mediante pruebas controladas y no destructivas. Si al cambiar el identificador del cliente se logran ver los datos de otra persona, se comprueba una falla de Control de acceso. También se intentará acceder al panel de administración sin los permisos debidos.

- Post-explotación:

Analizar el impacto real de lo descubierto. Observar qué tan lejos podría llegar un atacante real una vez dentro; a la información a la que podría acceder (tarjetas, direcciones, teléfonos) y los privilegios que podría obtener, cuidando de no dañar información real.

- Informe:

Escribir un documento final que resuma las fallas encontradas y explique detalladamente cómo solucionarlas bajo estándares OWASP. Este reporte, será entregado en fechas y formato estipulado con Aurora Market.

INVESTIGACIÓN.

Metodología elegida: OWASP WSTG (Guía de Pruebas de Seguridad para Aplicaciones Web).

¿Por qué?

Para el desarrollo de esta investigación metodológica, la opción más adecuada es la OWASP. Esta guía representa el estándar a nivel internacional para evaluar la seguridad en aplicaciones y servicios web, ofreciendo un marco de trabajo integral que combina técnicas de análisis para auditar plataformas interactivas. Esta metodología resulta especialmente útil y precisa para este proyecto debido a que el incidente reportado se origina en el comportamiento de la propia aplicación web frente a diferentes usuarios. La WSTG estructura sus procedimientos en categorías exhaustivas que atacan directamente los focos de riesgo del comercio electrónico, tales como la gestión de identidad, la autenticación, el manejo de sesiones, la validación de entradas de datos y, fundamentalmente, las pruebas de autorización y control de acceso.

Al aplicar este marco de trabajo, el equipo puede ejecutar pruebas metódicas diseñadas para verificar si el sistema valida correctamente que quien solicita ver un pedido o un perfil realmente sea el dueño legítimo de esa información. Esto permite recrear de manera controlada el escenario del fallo reportado por el cliente, identificar si se trata de una referencia directa insegura a objetos o de una falla en los privilegios entre roles de usuario y administradores. Se evaluarían principalmente tres ítems; el control de acceso y visualización de datos; separación de privilegios; y autenticación y gestión de sesiones.